

Securing Agentic AI Solution using MCP and AI Data Gateway

- 1. Security Context:
- 2. Simplified request and response flow for AI Operations:
- 3. Security controls for MCP:
- 4. Security Controls for AI Gateway
- 5. Exceptions for Alex MCP Use case

Azure Service	Storage account
Author	@Raja Thiyagarajan ASP - Cybersecurity Architect
Reviewer	@Paul Smith and @Zachary Martignago (Data Team)
Date	Mar 6, 2026
Status	MCP - Review in progress AI Gateway - TBD
Version	0.2

1. Security Context:

Model Context Protocol (MCP) Server and AI Gateway are critical components of Agentic AI solution. This page reviews proposed Alex Data Catalog solution as primary usecase to define appropriate security requirements for Agentic AI Solution. So, it can be extended as a pattern for similar use cases in BSL.

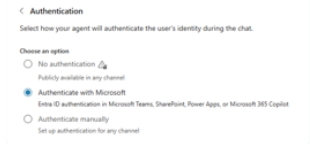
Reference SAD: [A.I within the Data Catalogue SAD v0.1.docx](#)

2. Simplified request and response flow for AI Operations:

Internal/External	Request Flow	Response Flow
BSL Internal	Teams' user ↓ (natural language prompt) Copilot Studio agent (LLM: intent + entities + decision) ↓ (structured call) Power Automate orchestration ↓ (authorized connector / secured HTTP) AI Gateway ↓ (Reverse Proxy for MCP) MCP Server (such as Alex MCP)	Teams User ↑ (natural language) CoPilot Studio Agent (LLM: Finalized wording response) ↑ Power Automate orchestration ↑ AI Gateway ↑ MCP Server (such as Alex MCP) - Structured result
BSL External	↓ (tool selection/lookup metadata) Backend/Third-Party APIs/Tools such as Alex APIs	↑ (metadata response) Backend/Third-Party APIs/Tools

3. Security controls for MCP:

Control ID	Solution Component	Capability	Category		Must/Should have	Note/Comment
SEC-AI-DTCTLG-01	MCP Server	Identity and Access Management	Authentication	Must use central Identify and Access management system (Entra ID) for all human and non-human identities	Must	User identity must be used to invoke authorized Alex APIs

				End users will engage with the AI Agents to carry out tasks on the Alex Platform. Data policy in power platform to restrict agent interaction authentication.	Must	reference: Configure data policies for agents - Microsoft Copilot Studio Microsoft Learn 
SEC-AI-DTCT LG-02		Secure Authorization	User Centric Authorization Per-user API tokens and must not use fixed credential for MCP server to invoke backend APIs in Alex platform Must not use Passthrough authentication.			
SEC-AI-DTCT LG-03	Network Security	Network flow control	NetSkope to route traffic between MCP server to whitelisted Alex domain/endpoints Alternatively, MCP outbound must be controlled via restricted firewall rules			Route all MCP client-server interactions through a trusted proxy

SEC-AI-DTCT LG-04		Applica tion Securit y	Supply chain risk and Governan ce	Static Scans: Scan MCP software/code using SAST/SCA against all libraries deployed. Dynamic Application Security Scan: No code with critical or high vulnerabilities in production Image governance: • Recommended to store base images sourced from BSL ACR internal container registry. • If use of an external registry is unavoidable, there should be a process to review and whitelisted authorized registries and endpoints allowed. • Application images must be stored within BSL ACRs	Must	Defender for Containers: Azure Platform team must enable agentless scanning of container images, runtime monitoring against MITRE ATT&CK for Containers
SEC-AI-DTCT			Input validation and	Input validation and context sanitization	Must	Confirm with vendor. If it's taken care by vendor MCP solution.

LG-05		sanitize context	Remove all unsafe content before passing the context to backend tools/APIs Sanitize template parameters for a any resource or action to prevent injection vulnerabilities.		
SEC-AI-DTCT LG-06		Secrets Management	All application secrets, if any, must be securely stored and retrieved from authorized secret management store such as Azure Key Vault. Note: Containers must not store secrets locally.		
SEC-AI-DTCT LG-07		Security hardening at Host	Ubuntu OS must be hardened on the following Remote connectivity to limited number of users using authorized encrypted channel and open public access must be disabled Restricted access to management ports Control on privileged admin access Patch level or OS version supported and		

			free from known critical or high vulnerabilities MCP server must be running under non-root user. Enforce resource limits CPU, Memory, concurrent users and tool call rate to prevent abusive workloads and resource contention		
SEC-AI-DTCT LG-08	Data Security	Detect and Protect Sensitive Data	<u>#1 Human in the loop:</u> Put human approval and policy gates in front of sensitive operations, with thresholds and contextual checks For e.g Use the Advanced tool in Alex MCP to execute data governance workflows <u>#2. Sensitive data detection:</u> Must have controls to detect and protection against the following attacks • Prompt injection	Must	<u>Implementation reference #1:</u> a user can ask an agent to request access to a sensitive dataset. The agent identifies the dataset as PII, asks the user for a business justification (a required field in the workflow), and then uses MCP tools (<code>list_alex_startable_workflows</code> , <code>get_alex_task_flow</code> , <code>submit_alex_task_response</code>) to formally launch the access request in Alex Solutions. reference: Pillar 3 in below page

				Tool injection		What is The Alex MCP Server? - Alex Solutions #2. Use AI Gateway for prompt injections
SEC-AI-DTCT LG-09		Monitoring and Logging		Monitor the MCP Server AI operations for risky actions and exfiltration patterns using BSL Approved Security tools CrowdStrike for endpoint security, and Qualys for vulnerability management at the host level.	Must	Data team to work with Cloud Operations team to ensure successfully installed security agents at MCP server (host level) and validate/resolve any process level issues on interaction between agents and application worker processes.
SEC-AI-DTCT LG-10		Monitoring and threat intelligence		Enable Defender for Cloud to get signals on threat intelligence and event correlation	Should	For continuous posture improvement and workload protection, compliance and threat management Cloud Operations and Cyber responsibility to work with MSFT for enablement.

4. Security Controls for AI Gateway

<TBD>

5. Exceptions for Alex MCP Use case

Security requirement	Data Team Reponse	Mitigation Factor
SEC-AI-DTCTLG-02: User Centric Authorization Per-user API tokens and must not use fixed credential for MCP server to invoke backend APIs in Alex platform Must not use Passthrough authentication.	Exception: Discussions with the Alex Solutions team has indicated this will always use the service principle for authentication.	This will be controlled by restricting the access to the agent to people who are allowed to see all the Data Catalog data. This will be a very small group. Risk : This mitigation ensures deployment control but fails to enforce per-user granularity or passing on user context at the API level. This leaves backend APIs vulnerable to broad access if the agent is compromised. Options: • Enforce token validation on Alex APIs with scopes tied to user identity and least-privilege claims. • Use On behalf flow setup via Entra ID (authorization server). Both options require discussion with Alex.

SEC-AI-DTCTLG-03: NetSkope to route traffic between MCP server to whitelisted Alex domain/endpoints	NetSkope is not installed on unix devices. IP to IP whitelisting is in place for current servers. This uses the Azure firewall as the egress point.	Okay to have Azure firewall being used as a control for egress. Must Ensure appropriate rules such as outbound ports and IP range are restricted.
SEC-AI-DTCTLG-04: Scan MCP software/code using SAST/SCA against all libraries deployed. No code with critical or high vulnerabilities in production	Scan MCP software/code using SAST/SCA against all libraries deployed. No code with critical or high vulnerabilities in production	As discussed, We need a quality assurance report from vendor on compliance for vulnerabilities whenever there is new release to our environment. Must not contain any critical or high vulnerabilities/CVEs open.
SEC-AI-DTCTLG-05: Dynamic Application Security Testing to detect	Looks like this requirement was cutoff mid sentence. happy to address if updated.	Same as above for DAST (Dynamic Application Security Testing) scans.
SEC-AI-DTCTLG-06: All application secrets, if any, must be securely stored and retrieved from authorized secret management store such as Azure Key Vault.	Exception: Credentials are required for the MCP server to connect back to Alex Solutions.	Mitigation control #1. Store Alex credentials in Key Vault , develop a custom script to automatically inject the credentials at runtime into

Note: Containers must not store secrets locally

environment variables from allocated KV secret store.

Mitigation control #2. Must rotate secrets every 90 days.

Review comment:

Ensure custom script doesn't do insecure handling (e.g., logging secrets in scripts etc)
Plus use native integration as much possible.

Permanent solution:

Store Alex credentials in Key Vault,

Assign a system-managed identity to the MCP container/pod, then grant "Key Vault Secrets User" RBAC role on the vault.

Then MCP app must fetch secrets via Azure SDK dynamically.